Anexo 19. Modelo de Amenazas STRIDE y Políticas de Seguridad

Capítulo: 4 (Definición y Evaluación de Arquitectura) | **Objetivo Específico:** OE3 | **Investigador:** Alvaro Felipe Lopez Russi | **Entidad:** ITY SAS / Universidad Católica de Colombia

1. Marco Metodológico STRIDE en Sistemas Multiagente con LLM

La incorporación de modelos de lenguaje e integraciones con APIs externas de redes sociales introduce vectores de ataque singulares que van más allá de la ciberseguridad clásica. Para proteger los activos de información de ITY SAS y garantizar el cumplimiento de la **Ley 1581 de 2012**, se aplicó el modelo de modelado de amenazas **STRIDE** (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege).

---

2. Matriz de Identificación de Amenazas y Mitigaciones Técnicas

Categoría STRIDE	Amenaza Específica Identificada	Componente Vulnerable	Nivel de Riesgo	Contramedida y Política de Mitigación Implementada
Spoofing (Suplantación)	Inyección de mensajes falsos simulando ser el supervisor para forzar publicación.	Colas de RabbitMQ y endpoints REST del agente.	**Alto**	Autenticación mutua en AMQP con credenciales dedicadas por servicio y tokens API Bearer.
Tampering (Alteración)	Prompt Injection mediante briefs maliciosos que intenten forzar al agente a divulgar secretos.	Agente de Ideación / LLM Gateway.	**Crítico**	Validación estricta con esquemas Pydantic y sanitización de entradas; aislamiento de contexto.
Repudiation (Repudio)	Publicación de contenido desalineado donde el operador alegue que el sistema actuó solo.	Módulo de entrega a Meta Suite (`/deliver`).	**Medio**	**Guarda de entrega HITL (ADR-008):** Registro inmutable en base de datos del ID de usuario aprobador.
Information Disclosure (Fuga de Información)	Filtración de lineamientos confidenciales entre marcas competidoras gestionadas por la agencia.	Memoria semántica RAG en PostgreSQL.	**Crítico**	**Aislamiento Multi-Tenant estricto:** Cláusula obligatoria `WHERE brand_id = :id` en consultas vectoriales.

Categoría STRIDE	Amenaza Específica Identificada	Componente Vulnerable	Nivel de Riesgo	Contramedida y Política de Mitigación Implementada
Denial of Service (Denegación de Servicio)	Saturación del LLM Gateway mediante avalancha de solicitudes de briefs concurrentes.	Inferencia de modelos Ollama en hardware host.	**Alto**	Limitador de tasa (*Rate Limiting*), caché semántica en Redis (TTL 1 h) y fallback automático.
Elevation of Privilege (Elevación de Privilegios)	Contenedor comprometido que intente acceder al socket Docker del host.	Contenedores de microservicios de herramientas.	**Medio**	Contenedores ejecutados como usuarios sin privilegios (`non-root`) y sin montaje de `/var/run/docker.sock` .

3. Conclusiones y Cumplimiento

El modelado STRIDE permitió blindar el sistema en sus capas de red interna, persistencia y procesamiento cognitivo, asegurando que la autonomía de los agentes no comprometa la integridad de las marcas atendidas por ITY SAS.